INFORMATION NETWORK SECURITY ADMINISTRATION (INSA)

Critical Mass Cyber Security Requirement Standard · version 2.0

Requirement-standard audit of MaJo Bridge as operator of MaJo e-School Bridge (MayaBela)

Cyber Security Requirement Audit Report

Auditee: Majo Bridge Technologies and Events PLC
Product / system: MaJo e-School Bridge (MayaBela) · multi-tenant school ERP

FAIL — NOT CONFORMANT

CMCSRS v2.0 organisational certification: not awarded.
Product technical controls remain strong. Mandatory national clauses (local cloud, accreditation, INSA reporting) are not met.

Document number	INSA-CMCSRS2-AUD-MB-2026-11-09
Audit date	9 November 2026 (Gregorian) · East Africa Time (Africa/Nairobi)
Criteria	Auditee-supplied PDF *Critical Mass Cyber Security Requirement Standard version 2.0* (INSA, 97 pages, A4). Tagged PDF; InDesign source; footer year 2017; introduction describes the second revision addressing emerging technology (cloud, AI, IoT, blockchain).
Related evaluation	INSA-CSMS-AUD-MB-2026-11-09-R3 against the *Cyber Security Audit and Evaluation Guideline* v1.0 (May 2015 E.C., 40 pages): **PASS Mature 86/100** on the submitted product + CSMS. That Guideline is a **different document**. The 86 score is not reused here.
Normative keywords	Part I §1.1: **Must** = absolute requirement; **Must not** = absolute prohibition; **Should** = highly recommended (justify any skip); **May** = optional. Part I §4.1 Enforcement: mandatory for the audience. Content type: organisations will be audited and certified on these requirements.
Target of audit	MaJo Bridge as a **key private organisation** (Scope §3) operating a system that stores children's records, plus the MayaBela source and CSMS pack. Live SQL on hosted project `hwkiihonthueadbhcvfi` was not applied (auditee instruction: keep classrooms running).
Classification	Restricted — auditee and auditor. Contains findings about children's data. Do not publish school passwords or keys.

1. Executive summary

Overall conclusion: MaJo Bridge is not yet conformant with CMCSRS v2.0 as an operating organisation. This standard is a **mandatory requirement catalogue**, not a 0–100 maturity scorecard. It has no Table 1. Certification is pass/fail on the MUST clauses that apply. Several MUST clauses fail: locally licensed cloud (§6.29.k), organisation-held encryption keys for classified cloud data (§6.29.f), system accreditation before processing classified information (§6.22.a), annual compliance reporting to INSA (§6.24), and designated

security-assessment positions under the national clearance scheme (§6.37). Those are not defects in Flutter tests. They are national-process and hosting requirements.

The earlier **86/100 Mature** result still stands **for the Guideline v1.0 evaluation of the submitted product CSMS**. It answers: “does the candidate have a CSMS and closed Major technical NCs?” This report answers: “does the operator meet CMCSRS v2.0 MUST clauses?” Different question, different result.

Partial	**Fail**	**N/A**
Capability 5.3–5.7	MUST processes (cloud, accreditation, reporting)	IoT · blockchain · ICS

What still holds from the product work: school isolation and driver need-to-know are CAAT-proven in source; privileged MFA (Admin + Finance) without locking teachers; Maya Assistant DPIA; CSMS pack adopted. Those close many *Should* technical items. They do not override a MUST on locally licensed cloud.

1.1 What this fail does and does not mean

- **Does:** INSA, if they audit MaJo Bridge against CMCSRS v2.0 as a key private operator of a live school system, can refuse organisational certification until the MUST cloud/accreditation/reporting gaps are treated (local CSP or INSA exception; accreditation; annual letter).
- **Does not:** cancel Guideline R3 (86/100) on the product candidate; require taking schools offline today; require forcing MFA on classroom teachers; require hiding login logos.

2. How this standard differs from the previous Guideline

	Guideline v1.0 (40 pages) — prior audit	CMCSRS v2.0 (97 pages) — this audit
Kind of document	How to audit and score a CSMS (people / process / technology; Table 1 0–100)	What organisations **must / should** implement (capability + 37 processes)
Pass rule	§8.5.e significance; Major NC blocks; 76–90 = Mature	MUST clauses; exceptional skips approved by INSA (§4.1 order-freedom)
Audience	Auditors and auditees	Federal/regional government and key private organisations
Emerging tech	Not the focus	Cloud (§6.29), AI (§6.30), IoT (§6.31), blockchain (§6.32)
Foreign hosting	Supplier/DPA as a process gap	**Must** use locally licensed CSPs (§6.29.k); no process fully outsourced to foreign actors (§6.2.e)

Method used here. Each applicable MUST is Conform or Non-conform. SHOULD is Conform, Partial, or Non-conform. N/A requires a written justification (standard §6.2.a) — recorded in `docs/csms/CSMS-CMCSRS-001-applicability.md`. Physical inspection of offices, INSA interviews, and live attack of production were out of scope (classrooms stay up).

3. Capability building (Part II §5)

Clause	Requirement (summary)	Result	Evidence / gap
5.3 Leadership	Top leadership owns cyber security; 0.5% of annual budget (5.3.j)	**Partial**	CSO appointment record exists. Budget 0.5% not evidenced. Disruptive-change consultation with INSA not done.
5.4 Governance	Cyber Security Department, security committee, liaison officers	**Partial**	Named CSO + RACI. No department/committee structure as drawn in §5.4.e–g (units may merge — still not documented as such).
5.5 Management	CSMS, policy, IRP, BCM, operational procedures; 80% from national CSMS (5.5.l)	**Partial**	CSMS pack adopted. National CSMS text was not attached, so 80/20 cannot be demonstrated.
5.6 Human	Awareness; National Career Path; national clearance for CIS admins	**Partial**	First-cycle awareness register. Career Path and national clearance files are not in the TOE.
5.7 Technology	Secure network, access control, malware, patching (minimum lists)	**Partial**	Product: RLS, MFA for Admin/Finance, CAAT. Organisation PCs/firewalls/malware agents: not evidenced in git. Default firewall password MUST (5.7.c.4) is an ops control, not a Flutter control.

4. Process results (Part II §6)

4.1 Not applicable (justified under §6.2.a)

Clause	Process	Justification
6.31	IoT	MayaBela does not deploy or operate IoT devices. School CCTV, if present, is the school's system.
6.32	Blockchain	No ledger, smart contract, or blockchain product.
6.15.e	ICS / SCADA	No industrial control system.

4.2 Major non-conformances (MUST / absolute)

A Major NC here is a failed **Must** (or an absolute prohibition such as §6.2.e) that substantially affects the capability of the operator to meet the standard's objectives for classified children's data.

ID	Clause	Finding	Can it be fixed without locking schools?
MNC-V2-01	6.29.k	**Locally licensed cloud.** "Governmental and key private organisations must use locally licensed cloud service providers." Live schools sit on a foreign-hosted shared project.	Yes — dedicated/on-prem instance (already offered) or INSA exception / local CSP. Do not cut over mid-day.
MNC-V2-02	6.29.f	**Keys in organisation custody.** Classified data in cloud must be encrypted at rest and in transit; "the encryption keys must be held by the organisation." Database encryption keys are the supplier's.	Yes — customer-managed keys or local hosting. Architecture change; not a classroom lockout.
MNC-V2-03	6.2.e · 6.38.i	**Foreign outsourcing.** No process may be fully outsourced to foreign actors. Classified ICT services should not be taken from a foreign supplier unless INSA approves an exception. Persistence, auth, and backups are fully on the foreign host.	Yes — same path as MNC-V2-01, plus a written INSA exception if they allow the current host.
MNC-V2-04	6.22.a · 6.22.h · 6.23.a	**Accreditation / certification.** Systems must be accredited before they process, store, or communicate sensitive or classified information; re-accreditation at least every two years; certification audit is part of that.	Yes — INSA process. Keep schools up while the file is prepared. Do not

ID	Clause	Finding	Can it be fixed without locking schools?
		MayaBela already processes CONFIDENTIAL children's data in production without an INSA accreditation decision.	claim the product is already accredited.
MNC-V2-05	6.24.d–g	**Annual compliance letter.** Must report mandatory-requirement compliance to the relevant Minister (or equivalent) and send a copy to INSA, including a head-of-organisation declaration and residual non-compliance.	Yes — CSO letter. No SQL. This report can be an annex to that letter.
MNC-V2-06	6.37.l · 6.37.k	**DSAP / eligibility.** Must identify designated security assessment positions that access CONFIDENTIAL+ assets and maintain a DSAP register; staff with ongoing access must be identity-established and suitable. A starter register is now in AST-001; national clearance files are still absent.	Yes — HR/INSA clearance. Teachers/parents/drivers are not DSAPs.

4.3 Minor non-conformances and partials

ID	Clause	Finding
mNC-V2-01	6.9	Git + CI exist; no formal change process that submits security-impacting changes to an accreditation authority, including urgent-change steps and reaccreditation when residual risk changes.
mNC-V2-02	6.5 / 6.7 / 6.11.n	Policy, CSMS, and risk assessments are not evidenced as consulted/informed to INSA.
mNC-V2-03	6.11	Risk register exists; not shown as 80% national/sector profile, SGOC+PESTLE strategic, six-month tactical, three-month operational.
mNC-V2-04	6.13.a,h	Product-team awareness register exists. MUST training for all staff including third parties, and training before unsupervised system access, is not evidenced for school users.
mNC-V2-05	6.14.f / 6.38.f–g	RAD/design not audited by INSA; product/service not INSA-certified before market (Should, but INSA may treat a live school system as if it were Must).
mNC-V2-06	6.16	No owned data centre. Office/laptop physical security policy as specified is not in the pack.
mNC-V2-07	6.18	TLS and PIN hashing exist. INSA-approved cryptographic systems / National PKI not used.
mNC-V2-08	6.21	Internal evaluation + CAAT exist. Internal auditors are not shown as INSA-certified; no INSA-certified third-party auditor yet.
mNC-V2-09	6.23.h	If Pages/API is viewed as a multi-organisation gateway, annual INSA Gateway Certification is absent.
mNC-V2-10	6.25 / 6.26	CAAT and IRP exist. Independent pentest letter still scheduled. Ethio-CER2T reporting step is now written into IRP-001; no live report has been sent (none due unless an incident is confirmed).
mNC-V2-11	6.28 / 6.19	Local restore drill 44 rows. Hosted backup/RPO remains the supplier. Event-log retention ≥ one month not proven on the host.
mNC-V2-12	6.30	DPIA + refuse-sensitive instruction: Partial conform for Maya Assistant. MUST risk-based adoption and privacy: addressed. SHOULD use of AI for cyber defence: not implemented (optional).
mNC-V2-13	6.33.n	Intelligence process cannot be outsourced to foreign actors. Using a foreign host's logs as the only monitoring channel remains a tension with this clause.
OBS-V2-PR	—	Hardened SQL (permission hardening + driver need-to-know) is in source and CAAT. Live project still lags until a notified window. Same reservation as Guideline R3 OBS-PR.

ID	Clause	Finding
OBS-V2-86	—	Do not reprint 86/100 on this cover. That number belongs to Guideline v1.0 Table 1 only.

4.4 Conformant (or sufficiently evidenced) clauses

Clause	Why it is not a Major against this TOE
6.8 / 6.2.a	Context, scope, and N/A justifications are now a CSMS record.
6.10.a	MUST asset inventory exists; Annex B labels applied (CONFIDENTIAL children’s records; PUBLIC logos and anon key).
6.17 (product half)	Access control aligns with business need: JWT school/role, RLS, driver need-to-know CAAT 9/9, two-school CAAT 7/7. Classification policy is now written; live labels on every row are not.
6.19.a	MUST BCM programme: BCM-001 adopted.
6.26.d (procedure)	MUST incident-reporting procedure exists; Ethio-CER2T added.
6.30.d,f (AI)	Risk-based DPIA; Assistant does not take names as live context; health/safeguarding refused.
6.36 (partial)	Privacy policy, retention, DPIA, children’s special-category handling described. Individual agreement (6.36.d) remains a school-enrolment matter.

5. Annex B classification used in this audit

CMCSRS v2.0 Annex B has four labels only: TOP SECRET, SECRET, CONFIDENTIAL, PUBLIC. This audit classifies:

- **CONFIDENTIAL:** student identity, marks, attendance, health/safeguarding collections, staff HR/payroll in the ERP, service-role key, CSMS pack.
- **PUBLIC:** school logos on the login branding bucket (no JWT on the login page); anon/publishable key (not a secret; RLS is the boundary); synthetic CAAT data.
- **SECRET / TOP SECRET:** not claimed. Unauthorised disclosure of a school register would damage children and the operator; it is not "exceptionally grave damage to national security" on the Annex B examples (widespread loss of life, military capability). If INSA later directs a higher label, MNC-V2-04 becomes stricter (TOP SECRET accreditation authority is INSA — §6.22.l).

6. Live school functionality (unchanged by this audit)

- No SQL applied to production `hwkiihonthueadbhcvfi`.
- Classroom teachers still write attendance, homework, and class notices; MFA stays opt-in for teachers and principals.
- School Admin and Finance MFA remain required (enrol prompt, not a login lockout).
- Login logos stay on the public branding bucket.
- Drivers still see **their** passengers and publish **their** GPS/scans (source CAAT; live apply still the notified window).

7. Corrective action to reach CMCSRS v2.0 organisational conformance

Guideline-style "close Minors in git this afternoon" will **not** flip this result. The blocking work is national and hosting:

1. **Treat MNC-V2-01/02/03:** ask INSA in writing whether the current host is an approved exception; if not, plan a locally licensed CSP or dedicated in-country instance. Keep the on-prem path for schools whose TOR already forbids shared foreign tenancy.
2. **Treat MNC-V2-04:** start accreditation: system owner letter, residual-risk statement, this report, Guideline R3, CSMS pack, CAAT evidence. Do not wait for a mid-day production cutover.
3. **Treat MNC-V2-05:** annual compliance declaration from the organisation head to the equivalent authority, copy to INSA, listing the residual MUSTs above.
4. **Treat MNC-V2-06:** fill DSAP files under the National Clearance Scheme when INSA issues the channel.
5. **Then** the notified staging→production SQL window (OBS-V2-PR) so the operating environment matches the hardened source, followed by the independent pentest letter already tracked in CSMS-TEV-001.

> **Cost-effective principle (Part I §4.4.c).** Do not force teacher MFA, hide logos, or invent a blockchain/IoT CSMS to "look complete." Those clauses are N/A or already treated. Spend the next effort on local cloud / INSA exception and accreditation — those are the MUST failures.

8. Statement of the auditor

This evaluation uses the auditee-supplied *Critical Mass Cyber Security Requirement Standard version 2.0* as the criteria, acting in the form of a regulatory-style auditor for advice before national engagement. It is **not** a gazetted INSA certificate and it does not authorise operation as if certified under CMCSRS v2.0.

Findings are evidence-based on the candidate repository, the adopted CSMS (including CSMS-CMCSRS-001), and the prior Guideline R3 fieldwork of 9 November 2026 (Africa/Nairobi). Where a MUST could not be evidenced, it is failed (Part I §1.1 Must = absolute). Live production was excluded from mutation by auditee instruction.

Audit conclusion: MaJo e-School Bridge / MayaBela, as an **operating organisation** processing CONFIDENTIAL children's data on a foreign-hosted shared cloud without INSA accreditation or an annual compliance letter, **does not yet conform** to CMCSRS v2.0. The product CSMS evaluated under Guideline v1.0 remains **Mature 86/100** for that other document. Classroom teachers, parents, and drivers were not locked by this work.

Lead auditor (evaluation team)	Auditee acknowledgement
Name / signature / date — 9 November 2026, East Africa Time	We have received this CMCSRS v2.0 report. We understand it does not replace Guideline R3, and we will respond with an action plan for MNC-V2-01 to MNC-V2-06.